

Security Scan Report

Target: <https://server.vulnapp.id/dvwa/login.php>

Scan Date: August 26, 2026 at 19:21 UTC

Scan ID: 97199bbe-16a8-4792-96e9-d1163893202e

0 CRITICAL

0 HIGH

2 MEDIUM

3 LOW

Executive Summary

Security scan of 'https://server.vulnapp.id/dvwa/login.php' identified 14 raw findings, reduced to 5 unique issues after deduplication. 2 MEDIUM-priority issue(s) should be addressed in the current development sprint. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	14
After Deduplication	5
Critical Findings	0
High Findings	0
Medium Findings	2
Low Findings	3
Scan Duration	44.9s

Detailed Findings

[MEDIUM] #1: Clickjacking in login.php:0

Risk Score	0.4462
Affected Location	https://server.vulnapp.id/dvwa/login.php:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation
The page can be embedded in an iframe, allowing attackers to overlay invisible controls and trick users into clicking. Found in login.php. Missing X-Frame-Options header.

Code or HTTP Excerpt

```
1 | Response headers: X-Frame-Options = (not set)
```

Business Impact
Users could be tricked into performing unintended actions on your application such as changing settings or transferring funds.

Fix Recommendation
Best Fix: Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors 'self'.

[MEDIUM] #2: Missing Security Header in login.php:0

Risk Score	0.4059
Affected Location	https://server.vulnapp.id/dvwa/login.php:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation
The server response is missing recommended HTTP security headers that instruct browsers to enable built-in protections. Found in login.php. Missing HTTP Strict-Transport-Security (HSTS) header.

Code or HTTP Excerpt

```
1 | Response headers: Strict-Transport-Security = (not set)
```

Business Impact
Without this header, user accounts and personal data is more vulnerable to XSS, clickjacking, or MIME-type confusion attacks.

Fix Recommendation
Best Fix: Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS connections and prevent SSL stripping.

[LOW] #3: Insecure Cookie in login.php:0

Risk Score	0.3920
Affected Location	https://server.vulnapp.id/dvwa/login.php:0
Vulnerability Type	INSECURE_COOKIE
CWE ID	CWE-614
Detected By	url-scanner

Explanation

One or more cookies are missing important security flags, making them vulnerable to theft or misuse. Found in login.php. Cookie 'PHPSESSID' is missing the Secure flag.

Code or HTTP Excerpt

```
1 | Set-Cookie: PHPSESSID=1372474b2a5c0e1072e475f236de9765; path=/
```

Business Impact

The session cookies cookie could be stolen via XSS or transmitted over insecure connections, enabling session hijacking.

Fix Recommendation

Best Fix: Set Secure, HttpOnly, and SameSite flags on all sensitive cookies.

[LOW] #4: Reconnaissance Surface in login.php:0

Risk Score	0.3500
Affected Location	https://server.vulnapp.id/dvwa/login.php:0
Vulnerability Type	RECONNAISSANCE_SURFACE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in login.php. Passive reconnaissance inventory of the reachable page.

Code or HTTP Excerpt

```
1 | Title: Damn Vulnerable Web App (DVWA) - Login
2 | Status: 200
3 | Content-Type: text/html; charset=utf-8
4 | Technologies disclosed: nginx/1.24.0 (Ubuntu), PHP/5.2.4-2ubuntu5.10
5 | Same-page links: 0
6 | Forms: 1
7 | Scripts: 0
```

Business Impact

This vulnerability could be exploited to compromise application security.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[LOW] #5: Information Disclosure in phpinfo.php:0

Risk Score	0.3492
Affected Location	https://server.vulnapp.id/phpinfo.php:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in phpinfo.php. PHP info page is publicly accessible — exposes server configuration details.

Code or HTTP Excerpt

```
1 | GET /phpinfo.php → HTTP 200
2 | Content-Length: 49135 bytes
3 | Preview: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd"
4 | <html><head>
5 | <style type="text/css">
6 | body {background-co
```

Business Impact

The disclosed configuration files helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Suppress the Server header version information. In nginx: `server_tokens off`; In Apache: `ServerTokens Prod`. In Flask: remove or override the Server header.

Appendix

Deduplication Statistics

Total raw findings: 14 | After deduplication: 5 | Reduction: 64%

Scan Metadata

Scan ID	97199bbe-16a8-4792-96e9-d1163893202e
Target	https://server.vulnapp.id/dvwa/login.php
Timestamp	2026-08-26T19:21:34.589594+00:00
Duration	44.9s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "93a1f6ad-ac05-48d0-8975-50bda8633a1f",
    "title": "Clickjacking in login.php:0",
    "file": "https://server.vulnapp.id/dvwa/login.php",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "CLICKJACKING",
    "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where",
    "rule_id": "header-missing-x-frame-options",
    "confidence": 0.85,
    "cwe_id": "CWE-1021",
    "cvss_score": null,
    "code_snippet": "Response headers: X-Frame-Options = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.4462,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The page can be embedded in an iframe, allowing attackers to overlay invisible content",
    "fix_suggestion": "Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors",
    "business_impact": "Users could be tricked into performing unintended actions on your application such as",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes real",
    "raw": {
      "url": "https://server.vulnapp.id/dvwa/login.php",
      "header": "X-Frame-Options",
      "check": "missing_header"
    }
  },
  {
    "id": "d3eec964-d598-42d4-a35e-5135585968ae",
    "title": "Missing Security Header in login.php:0",
    "file": "https://server.vulnapp.id/dvwa/login.php",
    "line_start": 0,
    "line_end": null,
```

```

"severity": "MEDIUM",
"vuln_type": "MISSING_SECURITY_HEADER",
"description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow c
"rule_id": "header-missing-strict-transport-security",
"confidence": 0.95,
"cwe_id": "CWE-319",
"cvss_score": null,
"code_snippet": "Response headers: Strict-Transport-Security = (not set)",
"sources": [
    "url-scanner"
],
"risk_score": 0.4059,
"risk_category": "MEDIUM",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server response is missing recommended HTTP security headers that instruct brow
"fix_suggestion": "Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS con
"business_impact": "Without this header, user accounts and personal data is more vulnerable to XSS, cli
"attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
"next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea
"raw": {
    "url": "https://server.vulnapp.id/dvwa/login.php",
    "header": "Strict-Transport-Security",
    "check": "missing_header"
}
},
{
    "id": "ed396c61-f316-40c8-865c-d2a2fa19ac46",
    "title": "Insecure Cookie in login.php:0",
    "file": "https://server.vulnapp.id/dvwa/login.php",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INSECURE_COOKIE",
    "description": "Cookie 'PHPSESSID' is missing the Secure flag. It may be transmitted over insecure HTTP
    "rule_id": "cookie-missing-secure",
    "confidence": 0.9,
    "cwe_id": "CWE-614",
    "cvss_score": null,
    "code_snippet": "Set-Cookie: PHPSESSID=1372474b2a5c0e1072e475f236de9765; path=/",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.392,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "One or more cookies are missing important security flags, making them vulnerable to
    "fix_suggestion": "Set Secure, HttpOnly, and SameSite flags on all sensitive cookies.",
    "business_impact": "The session cookies cookie could be stolen via XSS or transmitted over insecure con
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea
    "raw": {
        "url": "https://server.vulnapp.id/dvwa/login.php",
        "cookie": "PHPSESSID"
    }
},
{
    "id": "463c3dac-33fd-4597-ab8a-90561a877f13",
    "title": "Reconnaissance Surface in login.php:0",
    "file": "https://server.vulnapp.id/dvwa/login.php",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "RECONNAISSANCE_SURFACE",
    "description": "Passive reconnaissance inventory of the reachable page. Use the listed endpoints, forms,
    "rule_id": "recon-page-surface",
    "confidence": 1.0,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "Title: Damn Vulnerable Web App (DVWA) - Login\nStatus: 200\nContent-Type: text/html;cha

```

```

"sources": [
  "url-scanner"
],
"risk_score": 0.35,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "A security vulnerability was detected in your code. Found in login.php. Passive reco
"fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin
"business_impact": "This vulnerability could be exploited to compromise application security.",
"attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
"next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea
"raw": {
  "url": "https://server.vulnapp.id/dvwa/login.php",
  "surface": {
    "title": "Damn Vulnerable Web App (DVWA) - Login",
    "links": [],
    "scripts": [],
    "forms": [
      {
        "method": "POST",
        "action": "https://server.vulnapp.id/dvwa/login.php"
      }
    ]
  },
  "technologies": [
    "nginx/1.24.0 (Ubuntu)",
    "PHP/5.2.4-2ubuntu5.10"
  ]
},
{
  "id": "e1478d1f-0059-4f7d-84bc-fa09ba9a3314",
  "title": "Information Disclosure in phpinfo.php:0",
  "file": "https://server.vulnapp.id/phpinfo.php",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "PHP info page is publicly accessible \u2014 exposes server configuration details.",
  "rule_id": "sensitive-path-phpinfo.php",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /phpinfo.php \u2019 HTTP 200\nContent-Length: 49135 bytes\nPreview: <!DOCTYPE html
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
"fix_suggestion": "Suppress the Server header version information. In nginx: server_tokens off; In Apache
"business_impact": "The disclosed configuration files helps attackers identify attack vectors, reducing
"attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
"next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea
"raw": {
  "url": "https://server.vulnapp.id/phpinfo.php",
  "status": 200,
  "path": "/phpinfo.php"
}
}
]

```